

信息安全等级保护规范

技术规范文件

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

目录

- 1. 概述
- 2. 定级标准
 - 2.1 安全保护等级
 - 2.2 保险公司系统定级建议
- 3. 等保三级技术要求
 - 3.1 物理安全
 - 3.2 网络安全
 - 3.3 主机安全
 - 3.4 应用安全
 - 3.5 数据安全
- 4. 等保测评准备
 - 4.1 测评流程
 - 4.2 技术部门配合事项
- 5. 安全管理制度

信息安全等级保护规范

1. 概述

本文档定义落实《信息安全等级保护管理办法》(等保2.0)的技术要求，覆盖安全通用要求和安全扩展要求。适用于所有核心系统和涉及客户信息的应用系统。

2. 定级标准

2.1 安全保护等级

等级	定义	适用系统示例
第一级	自主保护	对外公开的门户网站
第二级	指导保护	内部办公系统
第三级	监督保护	核心业务系统(承保/理赔/收付/保单)
第四级	强制保护	涉及大量敏感个人信息的系统

2.2 保险公司系统定级建议

系统	建议等级	理由
承保中心	三级	涉及保费和客户信息
收付中心	三级	涉及资金交易
理赔中心	三级	涉及客户信息和资金
保单中心	三级	核心保单数据
客户中心	三级	大量个人信息
产品中心	二级	不直接涉及客户
办公OA	二级	内部管理信息

3. 等保三级技术要求

3.1 物理安全

要求项	技术实现
机房访问控制	门禁+指纹/人脸+记录
温湿度控制	精密空调+温湿度监控
电力供应	UPS + 发电机，续航 ≥ 4h
消防	气体灭火系统
视频监控	7×24h 录像，保存 ≥ 90天

3.2 网络安全

要求项	技术实现
网络隔离	VPC + 安全组 + 子网划分
访问控制	防火墙白名单，最小原则
入侵检测	IDS/IPS (Snort/Suricata)

要求项	技术实现
带宽管理	QoS 保障核心业务带宽
安全审计	网络流量日志，保存 ≥ 6个月

3.3 主机安全

要求项	技术实现
操作系统加固	基线扫描 + 最小服务原则
漏洞管理	月度扫描 + 季度渗透测试
防恶意代码	HIDS + 病毒查杀
登录控制	SSH Key + 堡垒机
审计日志	主机操作日志集中采集

3.4 应用安全

参见《安全架构规范》第4-5节，等保三级要求重点关注：

- 身份鉴别：双因素认证
- 访问控制：细粒度权限、强制访问路径
- 安全审计：应用日志覆盖所有用户操作
- 数据完整性：校验码/数字签名
- 通信保密性：全链路加密

3.5 数据安全

要求项	技术实现
数据分类	按敏感度分级
数据加密	AES-256 存储加密
备份恢复	每日全量 + 增量，异地备份
个人隐私	脱敏 + 加密 + 访问控制
数据销毁	磁盘消磁/物理粉碎

4. 等保测评准备

4.1 测评流程

□□□□ → □□□□ → □□□□ → □□□□ → □□□□

阶段	周期	产出物
定级备案	1个月	定级报告、备案证明
差距评估	2周	差距分析报告
整改建设	3-6个月	整改完成报告
等级测评	2周	测评报告
持续监督	持续	年审报告

4.2 技术部门配合事项

- 提供系统清单、网络拓扑、数据流向图
- 配合安全漏洞扫描和修复

- 提供安全管理制度文档
- 配合现场测评和人员访谈
- 整改完成后提供变更记录

5. 安全管理制度

等保三级要求建立以下制度文档：

制度类型	文档	技术部门配合
安全策略	总体安全策略方针	技术合规评估
人员安全	人员录用/离职安全管理	账号权限清理流程
系统建设	系统安全开发周期(SDL)	安全需求+安全测试
系统运维	日常操作、变更管理	运维SOP+自动化运维
应急响应	安全事件应急响应预案	应急演练+监报告警